

Secure Expense & Subscription Management API (ASP.NET Core)

This document describes a backend-only, security-focused ASP.NET Core project. The goal is to build an enterprise-grade API using a prebuilt testing database, with strong authentication, authorization, and defensive security mechanisms.

Project Goals

- 1 Secure user authentication (not just JWT)
- 2 Protection against common backend attacks
- 3 Audit logging and monitoring
- 4 Legacy-style database usage
- 5 Enterprise-grade ASP.NET Core architecture

Authentication & Security

- 1 Password hashing using ASP.NET Identity or Argon2
- 2 Login rate limiting and account lockout
- 3 Session-based or Access/Refresh token authentication
- 4 Session invalidation and rotation
- 5 CSRF protection when using cookies
- 6 Audit logs for sensitive actions

Roadmap Phases

- 1 Phase 1: Project setup and database integration
- 2 Phase 2: User registration and secure login
- 3 Phase 3: Authentication architecture
- 4 Phase 4: Authorization and access control
- 5 Phase 5: Expense and subscription APIs
- 6 Phase 6: Security hardening
- 7 Phase 7: Audit logging and monitoring
- 8 Phase 8: Advanced security features

This project mirrors real-world backend systems used in finance and SaaS products and is suitable as a portfolio-grade ASP.NET Core backend project.